COURSE: WEB SECURITY & PENETRATION TESTING

LAB ASSIGNMENT REPORT: DAY 42 API RECONNAISSANCE

Student Name: Jiwosh Shrestha	**Topic:** API Reconnaissance, Documentation & Endpoints
Assignment: Day 42 - API Recon	**Focus:** OWASP API Security - Endpoint Inventory & Mapping

PART 1: API RECONNAISSANCE & DOCUMENTATION CONCEPTS

Question 1: Define API reconnaissance. Why should recon happen before deeper API security testing?

API reconnaissance is the systematic process of discovering an API's base URL, available endpoints, HTTP methods, input parameters, authentication mechanisms, and documentation prior to performing active security testing or exploitation.

Reconnaissance must precede deeper security testing because it establishes a comprehensive inventory of the attack surface, prevents sending out-of-scope or destructive requests to non-existent endpoints, and allows security assessors to prioritize high-risk administrative or state-changing functions.

Question 2: Explain the difference between: human-readable documentation, machine-readable documentation, OpenAPI, and Swagger UI.

• Human-Readable Documentation: Technical documentation formatted as prose (HTML, Markdown, or PDFs) intended for human developers to read and integrate APIs.
• Machine-Readable Documentation: Structured data files (JSON or YAML) that security scanners, proxy tools, and automated code generators can parse automatically.
• OpenAPI: The industry-standard specification language for describing RESTful APIs in a standardized, machine-readable JSON/YAML format.
• Swagger UI: An interactive web interface tool that parses OpenAPI definitions to render human-friendly documentation and active in-browser API testing consoles.

Question 3: Explain API Base URL, Endpoint, and API Version. Give safe examples.

• Base URL: The root network address hosting the API service (e.g., https://api.example.com).
• Endpoint: A specific URI path under the base URL identifying a discrete resource or action (e.g., /users/42).
• API Version: The revision indicator for the API interface, embedded in the URL path or header to maintain backward compatibility (e.g., /v1/products or Accept: application/vnd.api.v2+json).

Question 4: Explain: Path Parameter, Query Parameter, Request Body Property, Response Schema.

• Path Parameter: A variable segment inside the URL path (e.g., /users/{id}).
• Query Parameter: Key-value pairs appended after ? in the URL providing optional filtering or pagination (e.g., ?page=2&status=open).
• Request Body Property: Data attributes encapsulated inside the JSON/XML payload of POST, PUT, or PATCH requests.

• Response Schema: The structural specification and data type rules governing successful API response payloads.

Question 5: Why should security testers compare API documentation with actual authorized application traffic?

Published API documentation is frequently incomplete, outdated, or intentionally omits administrative and deprecated endpoints. Comparing documentation against actual intercepted application traffic reveals undocumented, shadow, or legacy endpoints that remain active on the server, significantly expanding the attack surface.

PART 2: AUTHORIZED ENDPOINT INVENTORY & TRAFFIC MAPPING

Question 6: Endpoint Inventory (Day 42 PortSwigger Lab - Authorised Training Instance)

Method	Path	Purpose	Params	Auth
GET	/api/products	List products	None	None
GET	/api/products/{id}	Product detail	id (path)	None
POST	/api/products	Create product	name, price	Admin
PUT	/api/products/{id}	Replace product	id, body	Admin
DELETE	/api/products/{id}	Delete product	id (path)	Admin
GET	/api/user	Current user	None	Required
GET	/api/orders	List orders	status?	Required



PART 3: AUTHORIZATION SCOPE & ETHICAL METHODOLOGY

Question 7: Explain why discovering a DELETE endpoint does NOT mean a tester should execute it automatically.

Discovering an endpoint expands the known inventory of system functionality; it does not grant authorization to execute state-changing or destructive requests.

Executing a DELETE request without explicit rules-of-engagement approval can cause catastrophic data loss, breach engagement scope, and violate computer misuse regulations. Professional penetration testing

methodology requires confirming that the target action is explicitly authorized before issuing high-risk requests. In the Day 42 assessment, DELETE /api/products/{id} was logged into the asset map but strictly left unexecuted.